

EU AI ACT PACK

EU AI Act — Counsel Briefing

Factual system description for external legal counsel

Lexy AI Hiring Platform · Generated 2026-07-20

Factual description of the system as built. Not legal advice; assumptions flagged for counsel.

Prepared: 20 July 2026 · For: external legal counsel Product: **Lexy** — AI-assisted hiring platform (SaaS, multi-tenant) Purpose of this document: a **factual description of what the system does and what compliance machinery already exists**, so counsel can advise on what Regulation (EU) 2024/1689 (the AI Act) and related law require of us. **Nothing here is a legal conclusion** — where we cite articles, that reflects our working engineering assumption, flagged for counsel to confirm or correct.

1. Why we believe we are in scope

- Lexy performs candidate **sourcing, resume screening/filtering, match scoring, AI-led interviews with automated grading, and outreach drafting** for recruitment.
- Working assumption: this is a **high-risk AI system under Annex III §4** (employment/workers management — recruitment and selection).
- Relevant deadline we are tracking: **2 August 2026** for high-risk obligations.
- Open question for counsel: whether Lexy is **provider, deployer**, or both, given the agency → client sub-tenant model (our customers are staffing agencies who run the system on behalf of their clients).

2. What the system actually decides — and what it does not

- AI produces **scores and recommendations** (match scores, interview grades, screening verdicts). Stage movements triggered by AI are recorded as such.
- Humans retain decision authority**: recruiters can override any AI recommendation; since July 2026 an override **requires a written rationale (≥10 characters, enforced server-side)**.
- A **kill switch and tenant scoping** govern every AI message endpoint; first-touch candidate outreach defaults to **human approval before send**.
- Automatic rejection emails and agent actions can be bypassed by an explicit recruiter “manual placement” flag — i.e. full manual operation is possible.

3. Compliance machinery already implemented (facts, with owners: engineering)

Area	What exists today
Candidate disclosure & consent	Versioned consent gate before every AI interview; the <code>/begin</code> endpoint refuses to start until consent for the current version is recorded. Consent copy discloses AI use, recording, and (since July 2026) the right to request human review . Written to satisfy overlapping notice duties (our working list: AI Act Art. 26(11), NYC LL144, Illinois AIVIA) — see <code>docs/legal/ai-consent-jurisdiction-memo.md</code> . Mid-interview consent revocation halts all capture server-side.
Contest / human review	Candidate-facing “Request human review” button on portal applications feeds a recruiter appeals queue with SLA visibility.
Human oversight metrics	Governance endpoint + dashboard panel showing override/deviation rate with a “rubber-stamp” alert when reviewers approve everything without deviation.
Logging / traceability	Per-decision <code>decision_events</code> records model, model version, prompt version, scoring version, orchestration version; never pruned . Stage changes flow through a single audited chokepoint

Area	What exists today
	(CI-enforced). Pipeline/agent runs have a durable event stream. STT (speech-to-text) outcome logs retained 365 days .
Accuracy monitoring	Per-provider and per-language STT accuracy/latency/empty-rate dashboards (Transcription Health). Interview grading calibration is versioned; a known open ticket exists on readiness-score length bias (tracked, disclosed internally).
Bias / fairness	Every candidate scorer is wrapped in a fairness directive + PII redaction before the model sees text ; demographics are firewalled from scoring (CI-enforced test). Adverse-impact monitoring (4/5ths rule) computed per job across the funnel. Candidate-facing score framing avoids raw discouraging numbers.
Data protection	GDPR erasure pipeline with a 30-day SLA timer on the deletion-request queue; erased/do-not-contact candidates excluded from every analytics and count surface (CI-enforced). PII handling documented in docs/PII_HANDLING.md . Data-deletion and appeal runbooks exist.
Technical documentation	docs/ANNEX_IV_TECHNICAL_DOCUMENTATION.md — a living skeleton structured per Annex IV, with repo-linked evidence per section and explicit TO-COMPLETE markers. Supporting: docs/AI_SYSTEM_CARD.md (model inventory), docs/AI_GOVERNANCE_ARCHITECTURE.md (oversight design).

4. Third-party AI providers in the chain

OpenAI (LLM scoring/drafting, Whisper STT), Azure Speech (STT/TTS), Sarvam (Indic STT), Deepgram and ElevenLabs (STT fallbacks), iFlytek (Chinese STT, being enabled), HeyGen (avatar video), People Data Labs & SERP providers (candidate sourcing data). **We do not yet have a consolidated DPA/contract register for these** — flagged as a gap.

5. Known gaps (engineering's honest list — for counsel to prioritise)

1. **Provider identity sections of Annex IV** are blank (legal entity, registered address, authorised representative if any).
2. **No quality management system (Art. 17)** formally stood up; no appointed compliance owner on paper.
3. **No conformity assessment / declaration of conformity / CE marking process** started.
4. **No consolidated risk register** with owners and review dates (risk controls exist in code; the register document does not).
5. **DPA/contract references for third-party AI providers** not compiled.
6. **Voice anti-spoofing** in interviews is heuristic-only; we deliberately do not claim robust deepfake detection.
7. **Post-market monitoring plan (Art. 72)** not formalised (monitoring exists; the plan document does not).
8. Readiness-score **length-over-substance bias** is a known open engineering ticket.
9. Production database schema for the newest compliance tables syncs only at next publish (an operational, not legal, note).

6. Questions we need counsel to answer

1. Provider vs deployer role split between Lexy, the staffing agency tenant, and the agency's end-client — who carries which Annex III §4 obligations?

2. Is our consent + disclosure copy sufficient for Art. 26(11) deployer information, and can one flow keep satisfying NYC LL144 / Illinois AIVIA simultaneously?
3. Does the human-review/appeal flow, as described, satisfy the human-oversight expectations (Art. 14) for a system of this kind, or is more required (e.g. four-eyes on rejections)?
4. What conformity-assessment route applies (internal control per Annex VI?) and what must be finished before 2 August 2026 versus what can follow?
5. Retention: is 365 days for STT/decision-relevant logs adequate, or should specific categories be longer (Art. 12 / Art. 19 record-keeping)?
6. Registration duties: does Lexy need to be registered in the EU database for high-risk systems, and by whom?
7. Any obligations triggered by the China-lane data flow (iFlytek processes candidate interview audio) — cross-border transfer analysis needed.

7. Documents included in this pack

1. This briefing (`EU_AI_ACT_LAWYER_BRIEFING`)
2. Annex IV technical documentation skeleton
3. AI System Card (model inventory & intended use)
4. AI Governance Architecture (oversight & decision enforcement design)
5. PII Handling
6. Consent jurisdiction memo (existing analysis of consent-notice overlap)
7. Appeal-handling runbook · Data-deletion runbook

All statements describe the system as of 20 July 2026. Engineering contact for follow-up questions: via the product team.